

JWT Auth System — Summary

Complete documentation of the JWT authentication implementation

■ Files Created

File	Purpose
services/tokenService.js	Generates & verifies access/refresh JWTs
services/sessionStore.js	In-memory Map tracking active refresh tokens per user
middleware/jwtMiddleware.js	requireJwtAuth – extracts & validates Bearer token from Authorization header
controllers/jwtAuthController.js	Sign-in, sign-up, refresh (with rotation), logout, profile
routes/jwtAuthRoutes.js	Route definitions mounted at /api/auth/jwt

⇒ ■ Files Modified

File	Change
app-api.js	Added JWT_ACCESS_SECRET + JWT_REFRESH_SECRET to required env vars, mounted
.env.example	Added JWT config template
.env	Appended generated JWT secrets + expiry settings

■ API Endpoints

Method	Endpoint	Auth	Description
POST	/api/auth/jwt/signup	None	Create account, returns tokens + user
POST	/api/auth/jwt/signin	None	Authenticate, returns tokens + user
POST	/api/auth/jwt/refresh	Body: { refreshToken }	Rotates both tokens
POST	/api/auth/jwt/logout	Body: { refreshToken }	Invalidates session
GET	/api/auth/jwt/profile	Bearer <accessToken>	Protected route, returns user info

■ Response Format

All endpoints return a consistent JSON format:

```
{ success, message, data: { user, accessToken, refreshToken } }
```

■■ How It Works

- 1. Sign In:** Server issues **access token (20m)** + **refresh token (30d)**, stores refresh token in the session Map.
- 2. API Calls:** Frontend sends `Authorization: Bearer <accessToken>`, middleware decodes and attaches `req.user`.
- 3. Token Expired:** Frontend calls `/refresh` with the refresh token → server verifies it exists in the Map, issues new pair, rotates (old refresh token is replaced).
- 4. Logout:** Server removes the session from the Map — refresh token is now useless.
- 5. 30 Days:** Refresh token expires — user must sign in again.

■ **Note:** The existing session-based auth (`/api/auth/*`) is untouched — both systems work side by side. Use `requireJwtAuth` middleware on any route you want to protect with JWT instead of `requireAuth`.